Plano de Operação e Segurança - LeiteTech Soluções

Procedimentos de operação e segurança dos sistemas da LeiteTech (50 funcionários, 4 andares). Responsável geral: equipe de TI. As regras de rede (firewall de borda, ACLs) estão na disciplina de Redes.

Controle	Do que	Responsável	Frequência	Como verificar
Atualizações	Windows e Ubuntu atualizados por GPO (Windows Update) e unattended-upgrades. Testar em 1 máquina antes de liberar para todas.	TI	Semanal, após as 18h	Relatório de atualização no servidor AD01; máquinas sem a atualização listadas e tratadas em até 7 dias.
Proteção contra malware	Microsoft Defender com proteção em tempo real e verificação semanal, gerenciado por GPO.	TI	Contínua; verificação semanal	Painel do Defender: nenhuma estação desatualizada ou com proteção desligada; alertas revisados toda semana.
Firewall	Firewall do Windows ativo nas estações por GPO; regras de rede conforme Redes.	TI	Revisão mensal	Comando de status do firewall em amostra de estações; GPO aplicada (gpresult).
Criptografia	BitLocker nos 10 notebooks, chave de recuperação guardada no AD.	TI	Na entrega do notebook; conferência trimestral	Lista de notebooks com BitLocker ativo e chave presente no AD.
Registro de eventos (logs)	Logins, falhas e alterações em contas guardados por 90 dias nos servidores.	TI	Guardar sempre; revisar semanalmente	Visualizador de eventos e MON01: falhas repetidas de login e criação de contas fora do padrão.
Contas administrativas	Usuário comum sem administrador local. Administração só com conta separada, no grupo GG-TI-Admin, com autenticação em dois fatores.	TI	Revisão trimestral	Lista de membros de GG-TI-Admin comparada com a equipe de TI; sem contas administrativas de uso diário.
Senhas	Mínimo de 12 caracteres, bloqueio de 15 min após 5 erros, troca imediata se houver suspeita de vazamento.	TI	Contínua (GPO)	Política de senha do domínio conferida em gpresult e nas configurações do AD.
Mídias removíveis	Pen drives bloqueados nas estações; liberação só por pedido ao TI.	TI	Contínua (GPO); revisão dos pedidos mensal	Teste com pen drive em 1 estação; registro dos pedidos liberados.
Entrada de funcionário	RH avisa a TI; TI cria a conta no AD, coloca nos grupos do setor e entrega o equipamento com o perfil correto.	RH e TI	A cada contratação, antes do 1º dia	Conta no grupo GG correto; login de teste feito; equipamento registrado no inventário.
Saída de funcionário	RH avisa a TI; conta desativada no mesmo dia, acesso remoto removido, equipamento devolvido e recebido pela TI.	RH e TI	A cada desligamento, no mesmo dia	Conta desativada no AD; sem logins após a data; equipamento conferido no inventário.
Mudança de setor	TI troca os grupos do usuário e remove as	RH e TI	A cada mudança	Usuário só aparece nos grupos do novo setor.

	permissões do setor anterior.			
Acesso físico	Sala de servidores trancada no 4º andar, só a TI entra; temperatura monitorada pelo protótipo IoT.	TI	Contínua; revisão trimestral de quem tem chave	Lista de quem tem chave; alertas de temperatura no monitoramento.